RESEARCH PROPOSAL

An Uncertainty-Aware Multi-Agent LLM Framework with Retrieval-Augmented Generation for Evidence-Based Web Application Vulnerability Assessment

RAG-সমন্বিত অনিশ্চয়তা-সচেতন Multi-Agent AI দিয়ে প্রমাণভিত্তিক ওয়েব অ্যাপ্লিকেশন দুর্বলতা নিরূপণ

নির্বাহী সারাংশ (Executive Summary)

বৃহৎ ভাষা মডেল (LLM)-চালিত AI Agent জটিল ওয়েব অ্যাপ্লিকেশনের নিরাপত্তা পরীক্ষায় পরিকল্পনা, টুল ব্যবহার এবং পরীক্ষার ফল বিশ্লেষণে সহায়তা করতে পারে। তবে এ ধরনের সিস্টেম ভুলভাবে vulnerability শনাক্ত করতে পারে, আগের পরীক্ষার প্রসঙ্গ হারাতে পারে, অথবা প্রমাণ অপর্যাপ্ত থাকা সত্ত্বেও আত্মবিশ্বাসী সিদ্ধান্ত দিতে পারে। একই সঙ্গে, স্বায়ত্তশাসিত নিরাপত্তা পরীক্ষা অনিয়ন্ত্রিত হলে অনুমোদিত পরিসর অতিক্রম করার ঝুঁকি থাকে।

এই গবেষণায় Retrieval-Augmented Generation (RAG)-সমন্বিত Multi-Agent LLM Framework প্রস্তাব করা হচ্ছে, যেখানে Reconnaissance/Observation, Test Planning, Guarded Execution, Knowledge Retrieval, Evidence Verification, Uncertainty Decision এবং Reporting-এর কাজগুলো নিয়ন্ত্রিত workflow-তে সম্পন্ন হবে। RAG মডিউল প্রাসঙ্গিক নিরাপত্তা নথি ও পূর্বে যাচাইকৃত ল্যাব ফলাফল উদ্ধার করবে; Evidence Verifier finding-এর পক্ষে নির্ধারিত প্রমাণ পরীক্ষা করবে; আর Uncertainty Module confidence score ও evidence quality বিবেচনা করে পুনরায় যাচাই, abstention অথবা human review-এর সিদ্ধান্ত নেবে।

প্রোটোটাইপটি কেবল অনুমোদিত, বিচ্ছিন্ন ও স্থানীয়ভাবে চালিত test environment-এ মূল্যায়ন করা হবে। প্রাথমিক পরিধিতে XSS, SQL Injection এবং Broken Access Control-এর নির্বাচিত test case থাকবে। ফলাফল OWASP ZAP, uncertainty module বন্ধ রাখা Multi-Agent+RAG সংস্করণ এবং সম্পূর্ণ প্রস্তাবিত সংস্করণের সঙ্গে তুলনা করা হবে। Precision, Recall, F1-score, False-positive rate, confidence calibration, abstention rate, safety compliance, runtime এবং tool-call count মূল্যায়ন করা হবে। গবেষণার মূল অনুমান হলো—evidence-based verification ও uncertainty-aware control ভুল vulnerability report কমাতে পারে, তবে এর ফলে detection coverage বা runtime-এ কী trade-off হয় তা পরীক্ষার মাধ্যমে নির্ধারণ করতে হবে।

মূল শব্দ: Large Language Models, Multi-Agent Systems, Retrieval-Augmented Generation, Uncertainty Estimation, Evidence Verification, Web Application Security, Vulnerability Assessment.

সূচিপত্র (সংক্ষিপ্ত)

- ১. ভূমিকা ও পটভূমি
- ২. সমস্যা বিবৃতি
- ৩. সংশ্লিষ্ট গবেষণা ও প্রস্তাবিত Research Gap
- ৪. গবেষণার লক্ষ্য ও উদ্দেশ্য
- ৫. গবেষণা প্রশ্ন ও অনুমান
- ৬. পরিধি ও সীমাবদ্ধতা
- ৭. প্রস্তাবিত সিস্টেম স্থাপত্য
- ৮. গবেষণা পদ্ধতি ও পরীক্ষার নকশা
- ৯. মূল্যায়ন মেট্রিক্স
- ১০. প্রত্যাশিত অবদান
- ১১. সময়সূচি
- ১২. নৈতিকতা ও নিরাপত্তা
- ১৩. ঝুঁকি ও প্রশমন
- ১৪. উপসংহার
- ১৫. তথ্যসূত্র

১. ভূমিকা ও পটভূমি (Introduction & Background)

ওয়েব অ্যাপ্লিকেশনে ইনপুট হ্যান্ডলিং, authentication, authorization এবং API-ভিত্তিক কাজের ত্রুটি নিরাপত্তাজনিত ঝুঁকি তৈরি করতে পারে। Dynamic Application Security Testing (DAST) টুল অ্যাপ্লিকেশন পর্যবেক্ষণ ও পরীক্ষামূলক অনুরোধের মাধ্যমে কিছু দুর্বলতা শনাক্ত করতে পারে। তবে সব ধরনের business-logic বা access-control সমস্যা স্বয়ংক্রিয় স্ক্যানারে ধরা পড়ে না; OWASP ZAP-ও তার নথিতে উল্লেখ করে যে active scan কেবল নির্দিষ্ট ধরনের দুর্বলতা শনাক্ত করতে পারে এবং broken access control-এর মতো logical vulnerability স্বয়ংক্রিয় scanning-এ ধরা নাও পড়তে পারে [10].

LLM-ভিত্তিক penetration-testing গবেষণা পরিকল্পনা, টুল ব্যবহারে সহায়তা এবং পর্যায়ভিত্তিক কাজ বিশ্লেষণের সম্ভাবনা দেখিয়েছে [1–5]। একই সঙ্গে, LLM Agent-এর uncertainty quantification নিয়ে সাম্প্রতিক গবেষণা interactive agent-এ uncertainty estimator নির্বাচন, ভিন্ন ধরনের তথ্যের নির্ভরযোগ্যতা, uncertainty dynamics এবং সূক্ষ্ম পর্যায়ের benchmark-এর মতো চ্যালেঞ্জ তুলে ধরেছে [6]। এ দুই দিক একত্র করলে শুধু সম্ভাব্য দুর্বলতা খোঁজা নয়, finding কতটা নির্ভরযোগ্য এবং কখন আরও প্রমাণ দরকার—সেটিও মূল্যায়ন করা সম্ভব।

এই গবেষণার লক্ষ্য মানব penetration tester-কে প্রতিস্থাপন করা বা unrestricted attack capability তৈরি করা নয়। বরং একটি সীমিত-পরিসরের, নিয়ন্ত্রণযোগ্য এবং প্রমাণ-নির্ভর prototype নির্মাণ করে পরীক্ষা করা হবে—RAG, multi-agent workflow এবং uncertainty-aware decision policy একত্র করলে vulnerability report-এর নির্ভরযোগ্যতা ও নিরাপদ আচরণে পরিমাপযোগ্য উন্নতি হয় কি না।

২. সমস্যা বিবৃতি (Problem Statement)

LLM-চালিত security agent আংশিক পর্যবেক্ষণ, অনিশ্চিত tool output এবং অসম্পূর্ণ context-এর ওপর ভিত্তি করে পরবর্তী পদক্ষেপ নির্ধারণ করতে পারে। যদি Agent-এর অনুমানকে যথেষ্ট যাচাই ছাড়া চূড়ান্ত finding হিসেবে রিপোর্ট করা হয়, তাহলে false positive বাড়তে পারে। অন্যদিকে, যদি Agent-এর সিদ্ধান্তে অনিশ্চয়তা থাকা সত্ত্বেও সে পরীক্ষা চালিয়ে যায়, তাহলে অপ্রয়োজনীয় অনুরোধ, সময় বা সম্পদের অপচয় এবং নির্ধারিত scope লঙ্ঘনের ঝুঁকি তৈরি হতে পারে।

অতএব মূল গবেষণা সমস্যা হলো: অনুমোদিত web-security test case-এ এমন একটি RAG-সমন্বিত Multi-Agent Agent কীভাবে নকশা ও মূল্যায়ন করা যায়, যা প্রাসঙ্গিক জ্ঞান উদ্ধার করে, evidence দিয়ে সম্ভাব্য vulnerability যাচাই করে, uncertainty পরিমাপ করে এবং প্রমাণ অপর্যাপ্ত হলে নিরাপদভাবে abstain বা human review-তে যায়—এবং এ পদ্ধতি baseline-এর তুলনায় false positive ও detection performance-এ কী প্রভাব ফেলে?

৩. সংশ্লিষ্ট গবেষণা ও প্রস্তাবিত Research Gap

৩.১ সংশ্লিষ্ট কাজের সারসংক্ষেপ

PentestGPT LLM-এর সাহায্যে penetration testing-এর কাজকে পরস্পর-সম্পর্কিত মডিউলে ভাগ করে এবং পরীক্ষার সময় সামগ্রিক context ধরে রাখার চ্যালেঞ্জ আলোচনা করে [1]। পরবর্তী benchmark-oriented কাজগুলো end-to-end সাফল্যের পাশাপাশি stage-level performance, testbed, baseline এবং evaluation protocol-এর গুরুত্ব তুলে ধরে [2–4]। ২০২৬ সালের PentestLLMAgent গবেষণায় task-dependency graph, hierarchical multi-agent architecture এবং পূর্বে যাচাইকৃত কমান্ড পুনরুদ্ধারের মতো কৌশল ব্যবহৃত হয়েছে [5]।

অন্যদিকে, LLM Agent-এর uncertainty quantification নিয়ে Oh et al. interactive agent-এর জন্য uncertainty estimation ও evaluation-এর বিশেষ চ্যালেঞ্জগুলো বিশ্লেষণ করেছেন [6]। OWASP Web Security Testing Guide ও OWASP Benchmark যথাক্রমে ওয়েব অ্যাপ্লিকেশন নিরাপত্তা পরীক্ষার কাঠামো এবং vulnerability-detection টুলের ফলাফল মূল্যায়নের সহায়ক উৎস [7–8]। OWASP Juice Shop একটি ইচ্ছাকৃতভাবে দুর্বল ওয়েব অ্যাপ্লিকেশন, যা security training ও tool testing-এর জন্য উপযোগী [9]।

সাহিত্য/উৎস	এই গবেষণার জন্য প্রাসঙ্গিক শিক্ষা
PentestGPT (2024) [1]	LLM-ভিত্তিক penetration-testing workflow-তে context management ও task decomposition গুরুত্বপূর্ণ।
Automated Pentesting Benchmark (2024) [2]	পুনরাবৃত্তিযোগ্য benchmark ও পৃথক testing stage দরকার।
Benchmarking Practices (2025) [3]	Testbed, baseline, metric এবং qualitative analysis স্পষ্টভাবে নির্ধারণ করা জরুরি।
PentestEval (2025) [4]	Stage-level ground truth ও automated evaluation LLM pentesting-এর সীমাবদ্ধতা দেখাতে সহায়ক।
PentestLLMAgent (2026) [5]	Multi-agent orchestration ও retrieved validated knowledge-এ ইতিমধ্যে গবেষণা হয়েছে; তাই শুধু এগুলোকে novelty বলা যাবে না।
Uncertainty Quantification in LLM Agents (2026) [6]	Interactive agent-এ uncertainty estimation, decision policy ও granular evaluation আলাদাভাবে বিবেচনা করা উচিত।
OWASP WSTG/Benchmark/Juice Shop [7–9]	পরীক্ষার scope, lab test case এবং ground-truth-ভিত্তিক মূল্যায়নের জন্য উপযোগী ভিত্তি।

৩.২ প্রাথমিক Research Gap

প্রাথমিক সাহিত্য পর্যালোচনা থেকে দেখা যায়, autonomous penetration testing-এ multi-agent orchestration, retrieval-ভিত্তিক জ্ঞান এবং benchmark evaluation নিয়ে একাধিক কাজ রয়েছে [1–5]। অপরদিকে, interactive LLM agent-এ uncertainty estimation ও uncertainty-নির্ভর সিদ্ধান্তের সাধারণ চ্যালেঞ্জগুলোও চিহ্নিত হয়েছে [6]। এই প্রস্তাবের সম্ভাব্য গবেষণার ক্ষেত্র হলো—নিয়ন্ত্রিত web-vulnerability test case-এ RAG-সমর্থিত multi-agent workflow-এর সঙ্গে স্পষ্ট evidence checklist, uncertainty-calibrated decision এবং low-confidence abstention যুক্ত করে false-positive reduction, detection coverage ও safety outcome-কে একই evaluation protocol-এ পরিমাপ করা।

এটি এখনো একটি প্রাথমিক research-gap hypothesis, প্রমাণিত novelty claim নয়। পূর্ণাঙ্গ literature review-তে এ ধরনের combination বা অনুরূপ evaluation আগে প্রকাশিত হয়েছে কি না যাচাই করতে হবে; overlap পাওয়া গেলে research question ও contribution সংশোধন করতে হবে।

৪. গবেষণার লক্ষ্য ও উদ্দেশ্য (Aim & Objectives)

সামগ্রিক লক্ষ্য হলো একটি নিয়ন্ত্রিত RAG-সমন্বিত Multi-Agent LLM prototype নির্মাণ এবং এর uncertainty-aware evidence verification পদ্ধতির কার্যকারিতা ও নিরাপত্তা তুলনামূলকভাবে মূল্যায়ন করা।

1. অনুমোদিত local web application-এ সীমিত test scope ও নিরাপদ execution policy সংজ্ঞায়িত করা।
2. Reconnaissance/observation, planning, guarded execution, RAG retrieval, evidence verification ও reporting-এর জন্য modular workflow নকশা করা।
3. প্রাসঙ্গিক security documentation ও পূর্বে যাচাইকৃত lab finding থেকে retrieval-ভিত্তিক context প্রদান করা।
4. প্রতিটি সম্ভাব্য finding-এর evidence quality ও uncertainty বিবেচনা করে verification, abstention অথবা human-review সিদ্ধান্তের নীতি তৈরি করা।
5. OWASP ZAP এবং uncertainty-disabled agent-এর সঙ্গে proposed system তুলনা করা; প্রয়োজনে RAG-অপসারণ ablation চালানো।

6. Precision, Recall, F1, false-positive rate, confidence calibration, abstention এবং safety metrics দিয়ে ফলাফল বিশ্লেষণ করা.

৫. গবেষণা প্রশ্ন ও অনুমান (Research Questions & Hypotheses)

নম্বর	গবেষণা প্রশ্ন
RQ1	RAG-সমর্থিত uncertainty-aware verification কি একই Multi-Agent+RAG baseline-এর তুলনায় false-positive vulnerability report কমায়?
RQ2	Uncertainty-aware পদ্ধতি যোগ করলে Recall বা detection coverage-এ কী প্রভাব পড়ে?
RQ3	Confidence score প্রকৃত finding reliability কতটা প্রতিফলিত করে, এবং score calibration কতটা ভালো?
RQ4	Low-confidence abstention ও safety guardrails scope compliance বজায় রাখতে এবং ঝুঁকিপূর্ণ পদক্ষেপ সীমিত করতে কতটা কার্যকর?
RQ5	RAG অপসারণ করলে report quality, tool-call count, runtime এবং evidence completeness-এ কী পরিবর্তন হয়?

প্রাথমিক অনুমান H1: একই test case ও একই execution budget-এ uncertainty-aware verification baseline-এর তুলনায় false-positive rate কমাবে। H2: abstention এবং অতিরিক্ত verification-এর কারণে false positive কমলেও কিছু ক্ষেত্রে recall বা runtime-এ trade-off হতে পারে। H3: confidence score যদি validation set-এ calibrate করা হয়, তবে তা uncalibrated self-reported confidence-এর তুলনায় ফলাফলের নির্ভরযোগ্যতা ভালোভাবে প্রতিফলিত করবে। এগুলো পরীক্ষা করার মতো অনুমান; ফলাফল আগাম ধরে নেওয়া হচ্ছে না।

৬. গবেষণার পরিধি ও সীমাবদ্ধতা (Scope & Limitations)

৬.১ অন্তর্ভুক্ত (In Scope)

- শুধু নিজস্ব বা লিখিত অনুমোদনপ্রাপ্ত, local, isolated lab environment-এ পরীক্ষা।
- প্রাথমিকভাবে তিনটি vulnerability class: reflected/stored XSS, SQL Injection-এর non-destructive test case এবং Broken Access Control-এর নির্দিষ্ট test case।
- OWASP Juice Shop এবং উপযোগী, labeled OWASP Benchmark test case থেকে বাছাই করা test set। দুই পরিবেশের test case সরাসরি বিনিময়ে ধরে নেওয়া হবে না; প্রতিটির ground truth আলাদাভাবে নথিভুক্ত হবে।
- RAG corpus হিসেবে OWASP WSTG, official tool documentation এবং sanitized, previously validated lab observations ব্যবহার।
- LangGraph বা সমমানের stateful workflow framework; ChromaDB বা সমমানের vector store; implementation সম্ভবতা অনুযায়ী স্থানীয় বা অনুমোদিত LLM।

৬.২ বাদ (Out of Scope)

- লাইভ third-party website scanning বা অনুমতি ছাড়া কোনো পরীক্ষা।
- WAF evasion, stealth masking, credential theft, denial-of-service, destructive payload, data exfiltration বা unrestricted exploit chaining।
- স্বয়ংক্রিয় remediation বা production deployment।

- সম্পূর্ণ autonomous IP-to-root penetration testing; গবেষণাটি নির্বাচিত web vulnerability class-এ সীমিত থাকবে।

মূল প্রস্তাবে adaptive WAF evasion একটি বিস্তৃত ধারণা ছিল; কিন্তু uncertainty-aware verification-এর অবদান নির্ভুলভাবে পরীক্ষা এবং undergraduate thesis-এর scope নিয়ন্ত্রণ করার জন্য WAF bypass/stealth-কে মূল গবেষণার বাইরে রাখা হয়েছে। প্রয়োজন হলে ভবিষ্যৎ কাজ হিসেবে, পৃথক অনুমোদিত lab protocol-এ বিষয়টি বিবেচনা করা যেতে পারে।

৭. প্রস্তাবিত সিস্টেম স্থাপত্য (Proposed System Architecture)

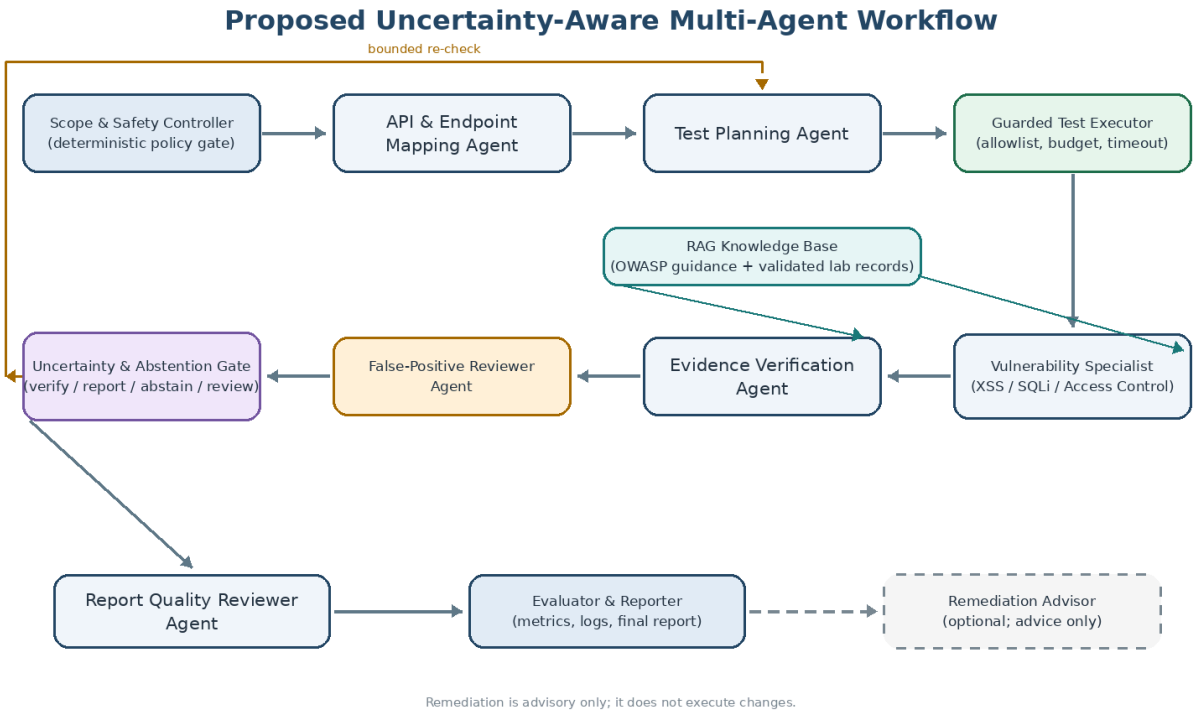
সিস্টেমটি LangGraph-এর মতো stateful workflow orchestration ব্যবহার করে বাস্তবায়ন করা যেতে পারে। LangGraph deterministic policy step ও LLM-driven step এক workflow-তে মিশিয়ে stateful agent flow এবং human-in-the-loop control সমর্থন করে [11]। RAG store-এ ChromaDB বা অনুরূপ vector database ব্যবহার করা যেতে পারে [12]। Framework ও model selection প্রাথমিক feasibility test-এর পর চূড়ান্ত হবে।

ধাপ/মডিউল	দায়িত্ব	নিয়ন্ত্রণ/আউটপুট
1. Scope & Safety Controller	অনুমোদিত host, path, request budget, timeout ও allowlist লোড করা।	অনুমোদনবহির্ভূত request ব্লক; audit log।
2. Observer / Recon Agent	পৃষ্ঠা, form, API route ও response metadata পর্যবেক্ষণ করা।	Application map; অনুমোদিত endpoint তালিকা।
3. Test Planner	নির্বাচিত vulnerability class অনুযায়ী অনুমোদিত test case পরিকল্পনা করা।	সীমাবদ্ধ test plan; বাজেট যাচাই।
4. Guarded Executor	শুধু policy-অনুমোদিত, non-destructive test request চালানো।	Request/response record; tool output।
5. RAG Analyst	প্রাসঙ্গিক security documentation ও validated lab record উদ্ধার করা।	সংশ্লিষ্ট নির্দেশনা ও উৎস-তথ্য।
6. Evidence Verifier	প্রত্যাশিত marker, response difference, tool evidence এবং পুনরাবৃত্ত ফল যাচাই করা।	Evidence checklist ও finding status।
7. Uncertainty Decision	evidence quality ও calibrated confidence অনুযায়ী verify / report / abstain / human review বেছে নেওয়া।	সিদ্ধান্তের কারণসহ uncertainty score।
8. Evaluator & Reporter	ground truth-এর সঙ্গে findings মেলানো এবং metrics/রিপোর্ট তৈরি করা।	JSON/CSV/SQLite findings; human-readable report।

৭.১ Finding-এর অবস্থা (Finding State)

অবস্থা	অর্থ	পরবর্তী পদক্ষেপ
Candidate	সম্ভাব্য দুর্বলতার প্রাথমিক ইঙ্গিত পাওয়া গেছে।	আরও evidence সংগ্রহ বা verifier-এ পাঠানো।
Verified	পূর্বনির্ধারিত evidence checklist ও ground-truth protocol অনুযায়ী যথেষ্ট সমর্থন আছে।	finding হিসেবে রিপোর্ট; evidence সংরক্ষণ।
Uncertain	প্রমাণ পরস্পরবিরোধী বা অপর্যাপ্ত।	সীমিত পুনঃযাচাই অথবা abstention/human review।

অবস্থা	অর্থ	পরবর্তী পদক্ষেপ
Rejected / Not Reproduced	যাচাইয়ে দাবি সমর্থিত হয়নি।	confirmed vulnerability হিসেবে রিপোর্ট নয়; audit trail রাখা।



Agent ও Module-এর দায়িত্ব (Agent / Module Responsibilities)

নতুন প্রস্তাবিত role-গুলোকে implementation priority অনুযায়ী আলাদা করা হয়েছে। “Agent” বলতে LLM-driven reasoning role বোঝানো হয়েছে; controller, executor এবং metric calculation-এর মতো নিরাপত্তা-সংবেদনশীল কাজ deterministic code-এ থাকবে।

Agent/Module	ধরন	মূল দায়িত্ব	আউটপুট/সীমা	অগ্রাধিকার
1. Scope & Safety Controller	Deterministic module	Allowlist, endpoint scope, timeout, redirect re-validation, request budget, API egress rule ও emergency stop enforce করা।	প্রতি run-এর policy decision ও audit log।	Must-have
2. API & Endpoint Mapping Agent	LLM agent + bounded tools	অনুমোদিত app-এর page, form, route, API endpoint ও parameter metadata সংগঠিত করা।	Endpoint inventory; unsupported route নিজে থেকে scan নয়।	Must-have

Agent/Module	ধরন	মূল দায়িত্ব	আউটপুট/সীমা	অগ্রাধিকার
3. Test Planning Agent	LLM agent	নির্বাচিত vulnerability profile অনুযায়ী test case প্রস্তাব করা; budget ও policy pre-check করা।	সীমিত, reviewable test plan।	Must-have
4. Guarded Test Executor	Deterministic tool wrapper	শুধু allowlisted lab target-এ non-destructive request চালানো; response ও tool logs সংগ্রহ।	Request/response record; scope guard এড়াতে পারবে না।	Must-have
5. RAG Analyst	Retrieval + LLM synthesis	OWASP guidance, official documentation ও validated lab records থেকে প্রাসঙ্গিক context উদ্ধৃত করা।	Source/provenance-সহ context; retrieval নিজে proof নয়।	Must-have
6. Vulnerability Specialist Agent	Reusable LLM role with 3 profiles	XSS, SQL Injection ও Broken Access Control-এর পৃথক prompt/criteria ব্যবহার করে candidate finding বিশ্লেষণ।	Candidate finding + evidence required list।	Must-have
7. Evidence Verifier	LLM-assisted + deterministic checklist	Expected marker, response difference, repeatability ও tool evidence checklist যাচাই।	Evidence completeness ও verification state।	Must-have
8. False-Positive Reviewer Agent	Independent review pass	Candidate finding-এর counter-evidence, benign explanation, duplicate ও unsupported inference খোঁজা।	Support / challenge / unresolved recommendation; চূড়ান্ত policy gate নয়।	Core research addition
9. Uncertainty & Abstention Gate	Calibrated score + deterministic policy	Evidence quality ও validation-set-এ নির্ধারিত threshold অনুসারে report, bounded re-check, abstain বা human review নির্বাচন।	Decision + rationale + calibration log।	Must-have
10. Report Quality Reviewer Agent	Lightweight LLM/rule check	Citation/evidence reference, duplicate, severity wording ও contradictions পরীক্ষা করা।	Quality flags; unsupported finding নিজে confirmed করতে পারবে না।	Included, lightweight
11. Evaluator & Reporter	Mainly deterministic code	Ground truth-এর সঙ্গে findings map করে metrics, CSV/JSON log ও readable report তৈরি।	Reproducible metrics and report।	Must-have
12. Remediation Advisor Agent	Optional, non-executing LLM role	Verified finding-এর জন্য OWASP-aligned mitigation ও retest suggestion তৈরি।	Advice only; code change বা production action নয়।	Optional after core experiment

Finding State ও Decision Policy

অবস্থা	অর্থ	পরবর্তী পদক্ষেপ
Candidate	প্রাথমিক সম্ভাব্য ইঙ্গিত; এখনো confirmed নয়।	আরও evidence বা verifier/reviewer
Verified	Predefined checklist ও ground-truth protocol অনুযায়ী যথেষ্ট সমর্থন।	Evidence সহ report
Uncertain	Evidence অসম্পূর্ণ, বিরোধপূর্ণ অথবা confidence threshold-এর নিচে।	সীমিত re-check, abstain অথবা human review

অবস্থা	অর্থ	পরবর্তী পদক্ষেপ
Rejected / Not Reproduced	পুনরায় যাচাইয়ে claim সমর্থিত হয়নি।	Confirmed vulnerability হিসেবে report নয়; audit trail

৮. গবেষণা পদ্ধতি ও পরীক্ষার নকশা (Methodology & Experimental Design)

৮.১ গবেষণা পদ্ধতির ধরন

গবেষণাটি Design Science ও controlled comparative evaluation-এর সমন্বয়ে পরিচালিত হবে: (ক) সাহিত্য পর্যালোচনা ও protocol সংজ্ঞা, (খ) isolated lab ও ground-truth dataset প্রস্তুত, (গ) baseline এবং proposed prototype নির্মাণ, (ঘ) একই test set-এ পুনরাবৃত্ত পরীক্ষা, (ঙ) quantitative metrics ও qualitative error analysis, এবং (চ) ফলাফল ও সীমাবদ্ধতা প্রতিবেদন।

৮.২ RAG knowledge base

RAG corpus-এ থাকবে (১) OWASP WSTG-এর প্রাসঙ্গিক test guidance, (২) নির্বাচিত tool-এর official documentation, (৩) lab-এ নিশ্চিতভাবে যাচাইকৃত synthetic test case ও observation, এবং (৪) vulnerability class-এর সংক্ষিপ্ত ব্যাখ্যা ও evidence criteria। প্রতিটি item-এর source, version/date ও provenance metadata রাখা হবে। Retrieval result নিজে vulnerability-র প্রমাণ হিসেবে গণ্য হবে না; এটি কেবল test planning ও analysis-এ প্রাসঙ্গিক context দেবে. ChromaDB retrieval-এ embeddings ও metadata-filtering ব্যবহার করা সম্ভব [12].

৮.৩ Uncertainty ও confidence score

শুধু LLM-এর নিজস্ব ভাষায় বলা “আমি ৯০% নিশ্চিত” স্কোরকে একমাত্র confidence measure হিসেবে গ্রহণ করা হবে না। একটি প্রাথমিক composite score তৈরি করা হবে, যেখানে (ক) evidence checklist completeness, (খ) অনুমোদিত পুনঃযাচাইয়ের repeatability, (গ) স্বাধীন tool/output corroboration এবং (ঘ) observed response consistency-এর মতো নির্ধারিত সংকেত ব্যবহার করা হবে। RAG similarity score কেবল retrieval relevance নির্দেশ করবে—একে vulnerability confidence-এর সরাসরি প্রমাণ হিসেবে ধরা হবে না।

Composite score-এর ওজন ও abstention threshold development/validation set-এ নির্ধারণ করে test set-এ freeze করা হবে; test set দেখে threshold tune করা হবে না। Confidence calibration Brier Score ও Expected Calibration Error (ECE)-এর মতো metric দিয়ে পরিমাপ করা হবে। ছোট test set-এ calibration estimate অনিশ্চিত হতে পারে, তাই score-এর সঙ্গে sample size ও confidence interval/reporting caveat উল্লেখ করা হবে।

৮.৪ পরীক্ষার পরিবেশ ও Ground Truth

Primary target হিসেবে OWASP Juice Shop-এর local Docker instance ব্যবহার করা হবে [9]। OWASP Benchmark-এর কেবল উপযুক্ত ও ground-truth label-সহ নির্বাচিত test case ব্যবহার করা হবে [8]। আলাদা benchmark-এর data model ও vulnerability semantics আলাদা হতে পারে বলে test case-গুলো এক তালিকায় মিশিয়ে না দিয়ে source ও category অনুযায়ী tag করা হবে। প্রতিটি test case-এর expected vulnerability status, category, evidence checklist ও adjudication decision আগেই নথিভুক্ত করা হবে।

প্রাথমিক লক্ষ্য হবে প্রায় ৩০–৪৫টি curated test case প্রস্তুত করা; সম্ভব হলে তিনটি vulnerability class জুড়ে positive ও negative case ভারসাম্য রাখা হবে। চূড়ান্ত সংখ্যা lab setup ও ground-truth যাচাইয়ের পর

supervisor-এর সঙ্গে নির্ধারিত হবে। উন্নয়ন/validation test case ও final test set আলাদা রাখা হবে; সম্ভব হলে একই endpoint বা একই vulnerability instance বিভিন্ন partition-এ রাখা হবে না।

৮.৫ Baseline ও Ablation

সংস্করণ	বিবরণ	কী যাচাই করবে
B1: OWASP ZAP	একই অনুমোদিত target ও উপযুক্ত scan policy-তে baseline scan।	প্রচলিত DAST-এর তুলনামূলক performance।
B2: Multi-Agent + RAG	Multi-agent workflow ও RAG থাকবে; uncertainty-based abstention বন্ধ থাকবে।	Uncertainty module-এর অতিরিক্ত অবদান।
P: Proposed Agent	Multi-Agent + RAG + Evidence Verification + calibrated uncertainty + abstention।	সম্পূর্ণ প্রস্তাবিত পদ্ধতির ফলাফল।
A1: No-RAG ablation (সময় থাকলে)	পূর্ণ সিস্টেমের অন্য উপাদান একই রেখে RAG retrieval বন্ধ।	RAG-এর স্বতন্ত্র অবদান।

OWASP ZAP-এর active scan অনুমোদিত target-এ attack-like request পাঠাতে পারে; তাই এটি কেবল isolated lab-এ, configuration ও request budget নথিভুক্ত করে চালানো হবে [10]। broken access control-এর মতো logical flaw-এ ZAP-এর সীমাবদ্ধতা ফলাফল ব্যাখ্যা করার সময় উল্লেখ করতে হবে; একে সব vulnerability class-এর নিখুঁত baseline হিসেবে ধরা হবে না।

৮.৬ পরীক্ষার কার্যপ্রণালী

1. প্রতিটি test case-এর ground truth, category ও evidence checklist আগেই freeze করা।
2. B1, B2 ও P সংস্করণে একই target, অনুমোদিত scope এবং তুলনাযোগ্য resource/request budget ব্যবহার করা।
3. প্রতিটি case একাধিকবার চালানো (প্রাথমিকভাবে তিনবার, সম্ভব হলে) এবং model/configuration/version, prompt, retrieval source, tool log ও timestamp সংরক্ষণ করা।
4. প্রতিটি reported finding-কে ground truth-এর সঙ্গে adjudicate করে TP, FP, FN ও TN নির্ধারণ করা। Abstained case আলাদা করে নথিভুক্ত করা; সেগুলোকে অযথা true negative হিসেবে গণ্য না করা।
5. প্রধান ফলাফল ও baseline difference হিসাব করা; উপযুক্ত হলে bootstrap confidence interval এবং paired comparison ব্যবহার করা।
6. False positive, missed finding, incorrect confidence এবং guardrail violation-এর qualitative error analysis করা।

৯. মূল্যায়ন মেট্রিক্স (Evaluation Metrics)

মেট্রিক	সংজ্ঞা / সূত্র	ব্যাখ্যা
Precision	TP / (TP + FP)	রিপোর্ট করা finding-এর মধ্যে প্রকৃত finding-এর অনুপাত।
Recall	TP / (TP + FN)	ground-truth vulnerability-এর মধ্যে শনাক্ত হওয়া অংশ।
F1-score	2 × Precision × Recall / (Precision + Recall)	Precision ও Recall-এর harmonic mean।

মেট্রিক	সংজ্ঞা / সূত্র	ব্যাখ্যা
False-positive rate	FP / (FP + TN)	ground truth-এ vulnerability নেই এমন case-এ ভুল positive alert-এর হার।
Brier Score	$N^{-1} \Sigma(p_i - y_i)^2$	যেখানে p_i predicted probability ও y_i ground-truth binary label; কম মান সাধারণত ভালো probabilistic accuracy নির্দেশ করে।
Expected Calibration Error (ECE)	Confidence bin-এ accuracy ও confidence-এর ওজনযুক্ত পার্থক্য	confidence score কতটা calibrated, তা আনুমানিকভাবে দেখায়; bin/ছোট sample-এর সীমাবদ্ধতা জানাতে হবে।
Verified Finding Rate	Evidence checklist পাস করা finding / সব candidate finding	পূর্বনির্ধারিত criteria অনুযায়ী evidence verification-এর ফল।
Abstention Rate	Abstained decision / uncertainty decision প্রয়োজন এমন case	অনিশ্চয়তার কারণে কতবার report/অ্যাকশন স্থগিত করা হয়েছে।
Safety Compliance	নীতি-লঙ্ঘনহীন run / মোট run	Scope, request budget, timeout ও outbound-traffic policy মানা হয়েছে কি না।
Runtime / Tool Calls	প্রতি case-এর সময় ও tool-call count	নির্ভরযোগ্যতার বিনিময়ে অতিরিক্ত সময়/সম্পদের প্রয়োজন হচ্ছে কি না।

TP = True Positive, FP = False Positive, FN = False Negative, TN = True Negative। Metrics গণনার আগে “finding” ও “test case” কীভাবে map হবে তা নির্ধারণ করতে হবে। একাধিক finding একই vulnerability instance-এর সঙ্গে মিলে গেলে duplicate report কীভাবে গণনা হবে, সেটিও protocol-এ উল্লেখ করতে হবে।

১০. প্রত্যাশিত অবদান (Expected Contributions)

- নিরাপদ scope enforcement-সহ একটি modular Multi-Agent LLM prototype, যা deterministic policy checks ও LLM-driven analysis আলাদা করে।
- RAG-সমর্থিত context retrieval এবং পূর্বনির্ধারিত evidence checklist-ভিত্তিক vulnerability verification workflow।
- Low-confidence abstention ও human-review decision policy-এর controlled evaluation।
- একটি পুনরাবৃত্তিযোগ্য local-lab test protocol, labeled test-case log এবং error-analysis record।
- RAG ও uncertainty module-এর অবদান আলাদা করতে baseline comparison এবং, সম্ভব হলে, ablation result।

এ গবেষণা থেকে নিশ্চিতভাবে false positive কমবে বা মানব দক্ষতার সমান ফল হবে—এমন পূর্বঘোষণা করা হচ্ছে না। ফলাফল ইতিবাচক, মিশ্র বা নেতিবাচক যাই হোক, নির্ধারিত protocol অনুযায়ী তা প্রকাশ করা হবে।

১১. কার্যপরিকল্পনা ও সময়সূচি (Nine-Month Timeline)

সময়	প্রধান কাজ	ডেলিভারেবল
মাস ১	Literature review, research gap validation, supervisor feedback, test protocol draft।	সংশোধিত proposal ও protocol।
মাস ২	Lab setup, target/test-case selection, ground-truth labeling, baseline config।	Isolated testbed ও labeled test set v1।
মাস ৩	Scope controller, observer ও test-planning component।	Core workflow prototype।
মাস ৪	Guarded executor, logs ও safety-policy enforcement।	নিয়ন্ত্রিত execution pipeline।
মাস ৫	RAG corpus, ChromaDB retrieval ও provenance logging।	RAG-enabled analysis module।
মাস ৬	Evidence verifier, confidence score ও abstention policy; validation set-এ threshold selection।	Uncertainty-aware prototype।
মাস ৭	B1/B2/P experiment, repeated runs ও ablation (সম্ভব হলে)।	Experiment logs ও preliminary metrics।
মাস ৮	Statistical analysis, error analysis, limitations ও figures/tables।	Results & Discussion draft।
মাস ৯	Thesis writing, supervisor revision, final validation ও defense preparation।	Final thesis, reproducible protocol ও presentation।

১২. নৈতিকতা, নিরাপত্তা ও দায়িত্বশীল ব্যবহার (Ethics & Security)

1. সকল পরীক্ষা নিজের local lab বা লিখিত অনুমতিপ্রাপ্ত পরিবেশে চালানো হবে। কোনো live third-party target অন্তর্ভুক্ত হবে না।
2. Executor শুধুমাত্র allowlisted local host ও নির্ধারিত endpoint-এ request পাঠাবে; DNS/IP validation, redirect checks, per-test request budget, timeout এবং emergency stop থাকবে।
3. Experiment environment-এ outbound internet traffic default-deny থাকবে; dependency install প্রয়োজন হলে execution environment থেকে আলাদা করে করা হবে।
4. Destructive payload, denial-of-service, credential theft, secret collection, data exfiltration ও stealth/WAF-evasion behavior নিষিদ্ধ থাকবে।
5. কোনো বাস্তব credential বা ব্যক্তিগত ডেটা RAG corpus-এ রাখা হবে না; synthetic/test data ব্যবহার করা হবে।
6. প্রতিটি run-এর target, policy decision, request identifier, tool output, evidence ও final decision সংরক্ষণ করা হবে যাতে audit করা যায়।
7. Human oversight থাকবে: uncertainty threshold-এর নিচে বা policy exception হলে agent স্বয়ংক্রিয়ভাবে এগোবে না।

১৩. সম্ভাব্য ঝুঁকি ও প্রশমন (Risks & Mitigation)

ঝুঁকি	সম্ভাব্য প্রভাব	প্রশমন
Novelty overlap	অবদান পূর্ববর্তী কাজের সঙ্গে মিলে যেতে পারে।	মাস ১-এ systematic literature matrix; দাবি সংকীর্ণ করা।
Ground-truth/label noise	Precision/Recall ভুলভাবে হিসাব হতে পারে।	প্রতিটি case-এর label ও evidence checklist আগে নির্ধারণ; প্রয়োজনে দ্বৈত human review।
Unstable model outputs	একই case-এ ফল পরিবর্তিত হতে পারে।	Version/configuration freeze, repeat runs, full logs।
RAG retrieval noise	অপ্রাসঙ্গিক নথি ভুল সিদ্ধান্ত প্রভাবিত করতে পারে।	Source metadata, relevance threshold, citations/provenance logging; retrieval-কে proof না ধরা।
Scope violation/unsafe request	Lab-এর ক্ষতি বা অননুমোদিত request।	Policy enforcement model-এর বাইরে deterministic code-এ; allowlist, egress block, request caps ও kill switch।
Compute/time constraints	পূর্ণ multi-agent pipeline শেষ নাও হতে পারে।	প্রথমে minimal vertical prototype; model/tool choice feasibility test; optional ablation বাদ দেওয়ার fallback।

১৪. উপসংহার (Conclusion)

এই প্রস্তাবটি Multi-Agent LLM architecture ও RAG-ভিত্তিক knowledge retrieval-কে uncertainty estimation, evidence verification এবং safety guardrails-এর সঙ্গে একত্র করে একটি সীমিত-পরিসরের web vulnerability assessment framework পরীক্ষা করতে চায়। প্রস্তাবিত নকশার সবচেয়ে গুরুত্বপূর্ণ দিক হলো—শুধু vulnerability খুঁজে পাওয়া নয়, finding-এর প্রমাণযোগ্যতা, confidence score-এর নির্ভরযোগ্যতা, abstention behavior এবং নিরাপদ scope compliance-ও পরিমাপ করা।

গবেষণার সাফল্য নির্ভর করবে স্পষ্ট test protocol, যথাযথ ground truth, তুলনাযোগ্য baseline এবং honest error analysis-এর ওপর। Multi-Agent, RAG বা uncertainty-aware approach-এর novelty আগে থেকেই ধরে না নিয়ে পূর্ণ সাহিত্য পর্যালোচনার মাধ্যমে যাচাই করা হবে। এই সীমাবদ্ধতা বজায় রেখে কাজটি একটি বাস্তবসম্মত CSE thesis prototype হিসেবে এগিয়ে নেওয়া যেতে পারে।

১৫. প্রাথমিক তথ্যসূত্র (References)

[1] Deng, G., Liu, Y., Mayoral-Vilches, V., et al. (2024). PentestGPT: Evaluating and Harnessing Large Language Models for Automated Penetration Testing. Proceedings of the 33rd USENIX Security Symposium, 847–864.
https://www.usenix.org/conference/usenixsecurity24/presentation/deng

[2] Isozaki, I., Shrestha, M., Console, R., & Kim, E. (2024). Towards Automated Penetration Testing: Introducing LLM Benchmark, Analysis, and Improvements. arXiv:2410.17141.
https://arxiv.org/abs/2410.17141

[3] Happe, A., & Cito, J. (2025). Benchmarking Practices in LLM-driven Offensive Security: Testbeds, Metrics, and Experiment Design. arXiv:2504.10112.
https://arxiv.org/abs/2504.10112

[4] Yang, R., Cheng, M., Deng, G., Zhang, T., Wang, J., & Xie, X. (2025). PentestEval: Benchmarking LLM-based Penetration Testing with Modular and Stage-Level Design. arXiv:2512.14233.
https://arxiv.org/abs/2512.14233

[5] Sheng, S., Zhang, J., Yang, J., Cheng, K., & Qin, Z. (2026). PENTESTLLMAGENT: A Task Dependency Graph Planning-Based Multi-Agent Framework for Automated Penetration Testing. Proceedings of IJCAI 2026, 6518–6527.
https://www.ijcai.org/proceedings/2026/725

[6] Oh, C., Park, S., Kim, T. E., Li, J., Li, W., Yeh, S., Du, S., Hassani, H., Bogdan, P., Song, D., & Li, S. (2026). Uncertainty Quantification in LLM Agents: Foundations, Emerging Challenges, and Opportunities. ACL Anthology.
https://aclanthology.org/2026.acl-long.738/

[7] OWASP Foundation. Web Security Testing Guide (WSTG), Version 4.2 and current project documentation.
https://owasp.org/projects/web-security-testing-guide

[8] OWASP Foundation. OWASP Benchmark Project: Test suite for measuring vulnerability-detection tool speed and accuracy.
https://owasp.org/projects/benchmark

[9] OWASP Foundation. OWASP Juice Shop: Deliberately insecure web application for security training and tool testing.
https://owasp.org/projects/juice-shop

[10] ZAP by Checkmarx. Active Scan documentation and limitations.
https://www.zaproxy.org/docs/desktop/start/features/ascan/

[11] LangChain. LangGraph documentation: stateful agent orchestration and human-in-the-loop workflows.
https://reference.langchain.com/python/langgraph/overview

[12] Chroma. Chroma documentation: embeddings, vector search and metadata filtering.
https://docs.trychroma.com/

নোট: অনলাইন উৎসগুলো ২৪ অক্টোবর ২০২৬ তারিখে পর্যালোচনা করা হয়েছে। Literature review চলাকালে প্রতিটি গবেষণাপত্রের পূর্ণ লেখা, পদ্ধতি, সীমাবদ্ধতা ও citation details পুনরায় যাচাই করতে হবে।